Ecole Supérieure
d'Informatique et du Numérique
COLLEGE OF ENGINEERING & ARCHITECTURE

ETHICAL HACKING & DEFENSE

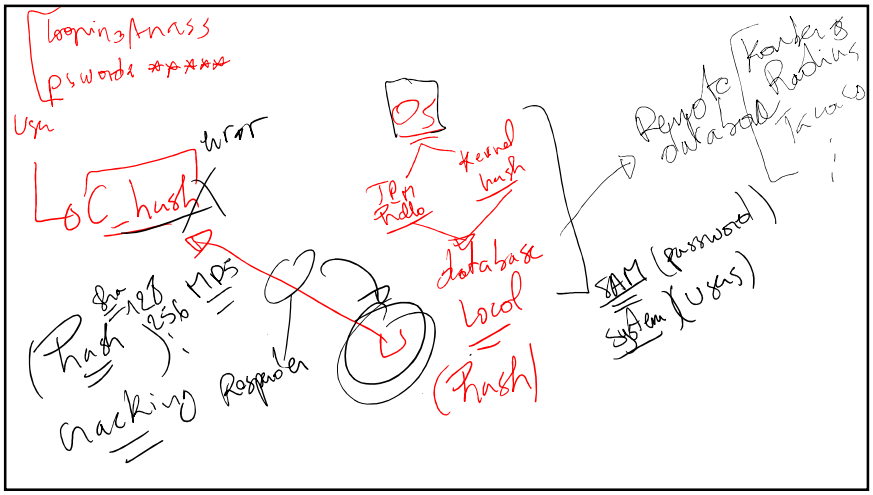
Certified Ethical Hacker

PRÉPARÉ PAR:
SEBBAR ANASS

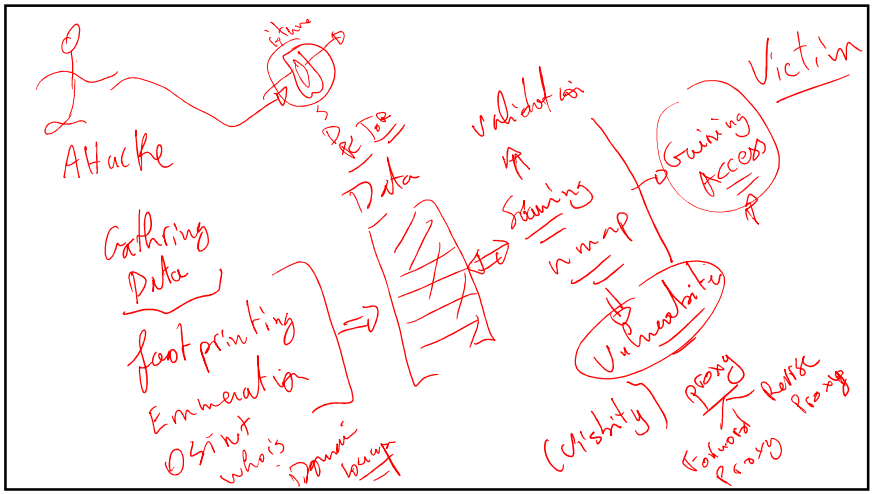
EC-COUNCIL | ACADEMIA
PARTNER

Année universitaire: 2026-2027

1



3



2



4

LEARNING OBJECTIVES

- LO#01: Demonstrate Different Password Cracking and Vulnerability Exploitation Techniques to Gain Access to the System
- LO#02: Use Different Privilege Escalation Techniques to Gain Administrative Privileges
- LO#03: Use Different Techniques to Hide Malicious Programs and Maintain Remote Access to the System
- LO#04: Demonstrate Techniques to Hide the Evidence of Compromise

5

LO#01: Demonstrate Different Password Cracking and Vulnerability Exploitation Techniques to Gain Access to the System

6

Password Cracking



Password cracking techniques are used to **recover passwords** from computer systems

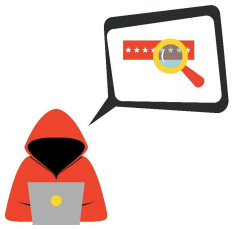
Attackers use password cracking techniques to **gain unauthorized access** to vulnerable systems

Most of the password cracking techniques are successful because of weak or easily **guessable passwords**

7

Password Complexity

1. Passwords that contain letters, special characters, and numbers **ap1@52**
2. Passwords that contain only numbers **23698217**
3. Passwords that contain only special characters **&*#@!(%)**
4. Passwords that contain letters and numbers **meet123**
5. Passwords that contain only letters **POTHMYDE**
6. Passwords that contain only letters and special characters **bob@&ba**
7. Passwords that contain only special characters and numbers **123@$45**



8

Microsoft Authentication

Security Accounts Manager (SAM) Database

- Windows stores user passwords in SAM, or in the **Active Directory database** in domains. Passwords are never stored in clear text and are hashed, and the results are stored in the SAM

NTLM Authentication

- The NTLM authentication protocol types are as follows: **NTLM authentication protocol** and **LM authentication protocol**
- These protocols store the user's password in the **SAM database** using different hashing methods

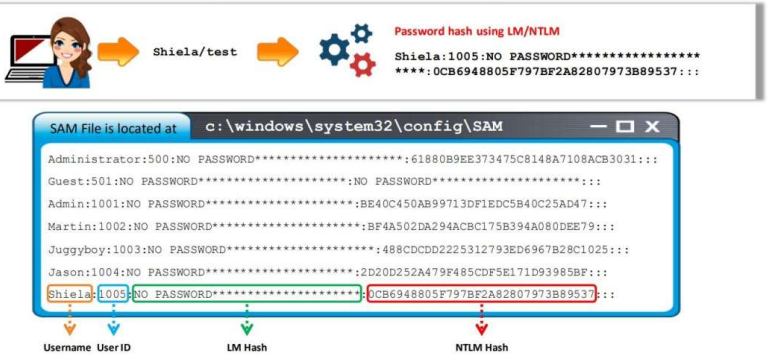
Kerberos Authentication

- Microsoft has upgraded its **default authentication protocol** to Kerberos which provides a stronger authentication for client/server applications than NTLM



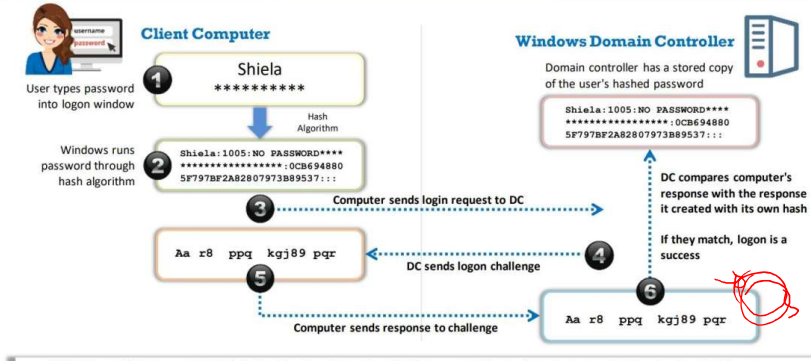
9

How Hash Passwords Are Stored in Windows SAM?



10

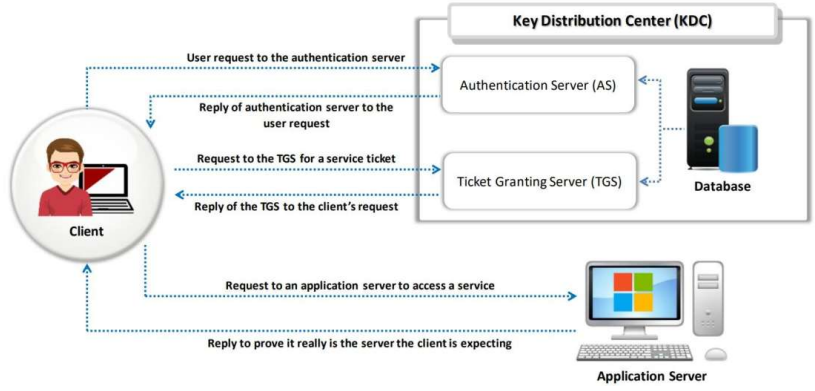
NTLM Authentication Process



Note: Microsoft has upgraded its default authentication protocol to Kerberos, which provides stronger authentication for client/server applications than NTLM.

11

Kerberos Authentication



12



Use of Hashed Passwords

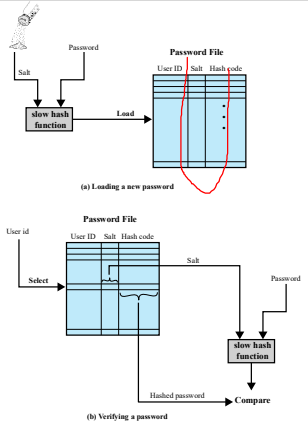


Figure 3.1 UNIX Password Scheme

13

UNIX Implementation

- original scheme
  - 8 character password form 56-bit key
  - 12-bit salt used to modify DES encryption into a one-way hash function
  - 0 value repeatedly encrypted 25 times
  - output translated to 11 character sequence
- now regarded as woefully insecure
  - e.g. supercomputer, 50 million tests, 80 min
- sometimes still used for compatibility

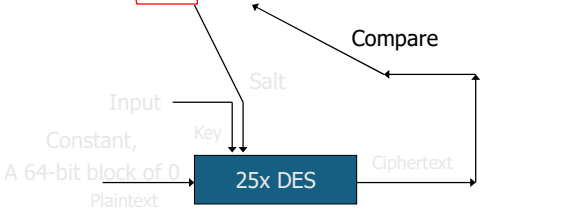
15

15

Salt

- Password line

walt:fURfuu4.4hY0U:129:129:Belgers:/home/walt:/bin/csh



When password is set, salt is chosen randomly
12-bit salt slows dictionary attack by factor of 2^{12}

14

Improved Implementations

- have other, stronger, hash/salt variants
- many systems now use MD5
  - with 48-bit salt
  - password length is unlimited
  - is hashed with 1000 times inner loop
  - produces 128-bit hash
- OpenBSD uses Blowfish block cipher based hash algorithm called Bcrypt
  - uses 128-bit salt to create 192-bit hash value

16

16

Password Cracking

- dictionary attacks
  - try each word then obvious variants in large dictionary against hash in password file
- rainbow table attacks
  - precompute tables of hash values for all salts
  - a mammoth table of hash values
  - e.g. 1.4GB table cracks 99.9% of alphanumeric Windows passwords in 13.8 secs
  - not feasible if larger salt values used

17

17

Password Choices

- users may pick short passwords
  - e.g. 3% were 3 chars or less, easily guessed
  - system can reject choices that are too short
- users may pick guessable passwords
  - so crackers use lists of likely passwords
  - e.g. one study of 14000 encrypted passwords guessed nearly 1/4 of them

18

18

Password File Access Control

- can block offline guessing attacks by denying access to encrypted passwords
  - make available only to privileged users
  - often using a separate shadow password file
- still have vulnerabilities
  - exploit O/S bug
  - accident with permissions making it readable
  - users with same password on other systems
  - access from unprotected backup media
  - sniff passwords in unprotected network traffic

19

19

Password Cracking

- Password cracking techniques are used to **recover passwords** from computer systems



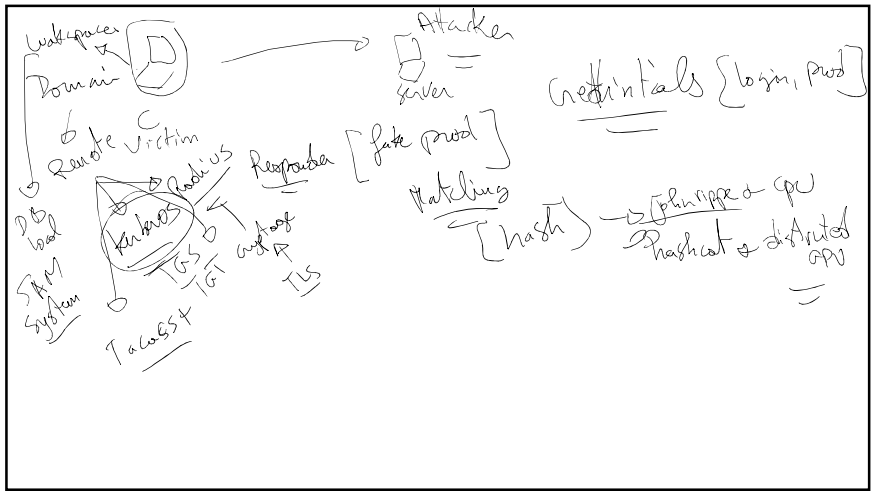
- Attackers use password cracking techniques to **gain unauthorized access** to vulnerable systems



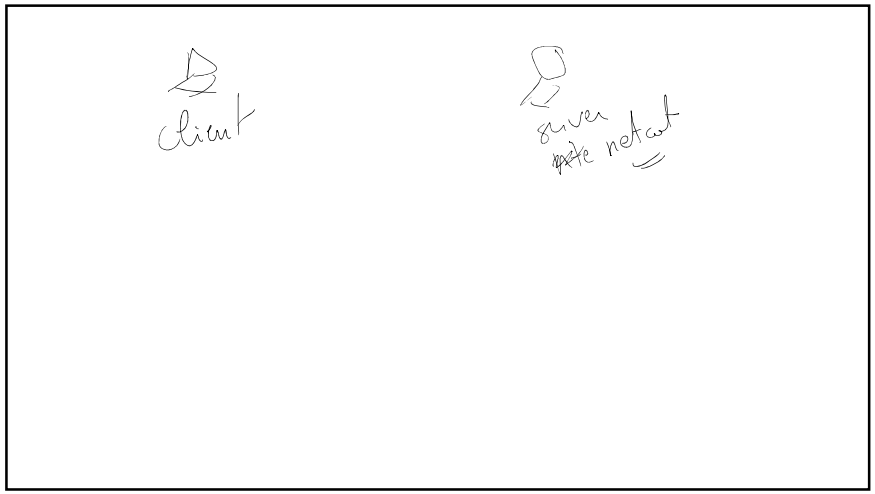
- Most of the password cracking techniques are successful because of weak or easily **guessable passwords**



20


Attacker
server
Credentials [login, pwd]
Remote Victim
Responder
[fake proof]
matching
[hash]
offline
cracking
hashcat
distributed GPU
DB load
SAM System
TGS
TGT
output
TLS
Tacacs+

21


client
server
write network

22

23

24

Types of Password Attacks

Non-Electronic Attacks	The attacker **does not need technical knowledge** to crack the password, hence it is known as a non-technical attack • Shoulder Surfing • Social Engineering • Dumpster Diving
Active Online Attacks	The attacker performs password cracking by **directly communicating** with the victim's machine • Dictionary, Brute Forcing, and Rule-based Attack • Hash Injection Attack/Mask Attack • LLMNR/NBT-NS Poisoning • Trojan/Spyware/Keyloggers • Password Guessing/Spraying • Internal Monologue Attack • Cracking Kerberos Passwords
Passive Online Attacks	The attacker performs password cracking **without communicating** with the authorizing party • Wire Sniffing • Man-in-the-Middle Attack • Replay Attack
Offline Attacks	The attacker copies the target's **password file** and then tries to crack passwords on his own system at a different location • Rainbow Table Attack (Pre-Computed Hashes) • Distributed Network Attack

25

Types of Password Attacks

Non-Electronic Attacks

The attacker **does not need technical knowledge** to crack the password, hence it is known as a non-technical attack

- Shoulder Surfing
- Social Engineering
- Dumpster Diving



01



Active Online Attacks

The attacker performs password cracking by **directly communicating** with the victim's machine

- Dictionary, Brute Forcing, and Rule-based Attack
- Hash Injection Attack
- LLMNR/NBT-NS Poisoning
- Trojan/Spyware/Keyloggers
- Password Guessing

02

26

Non-Electronic Attacks

Social Engineering	Shoulder Surfing	Dumpster Diving
Convincing people to reveal passwords	Looking at either the **user's keyboard or screen** while he/she is logging in	Searching for sensitive information in the **user's trash-bins, printer trash bins**, and in/on the user's desk for sticky notes







28

Types of Password Attacks (Cont'd)

Passive Online Attacks

The attacker performs password cracking **without communicating** with the authorizing party

- Wire Sniffing
- Man-in-the-Middle Attack
- Replay Attack



03



04

Offline Attacks

The attacker copies the target's **password file** and then tries to crack passwords on his own system at a different location

- Rainbow Table Attack (Pre-Computed Hashes)
- Distributed Network Attack

27

Active Online Attacks: Dictionary, Brute-Force, and Rule-based Attack

Dictionary Attack

- A **dictionary file** is loaded into the cracking application that runs against **user accounts**



Brute-Force Attack

- The program tries **every combination of characters** until the password is broken



Rule-based Attack

- This attack is used when the attacker gets some **information about the password**



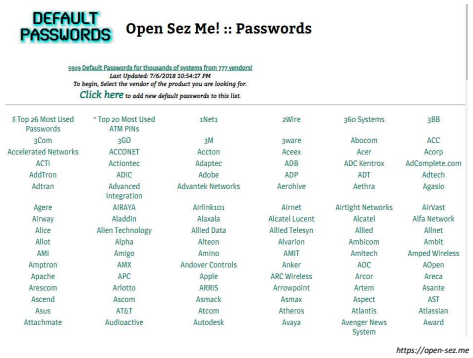
29

Default Passwords

- A default password is a **password supplied by the manufacturer** with new equipment (e.g., switches, hubs, routers) that is password protected
- Attackers use **default passwords** present in the list of words or dictionary to **perform password guessing attack**

Online Tools to Search Default Passwords

- ✓ *https://www.fortypoundhead.com*
- ✓ *https://cirt.net*
- ✓ *http://www.defaultpassword.us*
- ✓ *https://www.routerpasswords.com*
- ✓ *https://default-password.info*



31

Password Guessing

Frequency of attacks is less

The attacker creates a list of all possible passwords from the information collected through **social engineering** or any other way and manually inputs them on the victim's machine to **crack the passwords**

Failure rate is high

1. Find a **valid** user
2. Create a **list** of possible passwords
3. Rank passwords from **high to low** probability
4. Key in each password, until the **correct password** is discovered

30

Active Online Attacks: Password Spraying Attack and Mask Attack

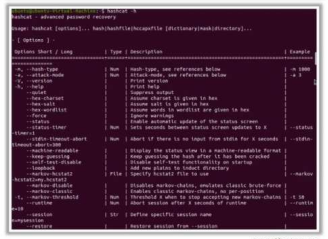
Password Spraying Attack

- Attackers **target multiple user** accounts simultaneously and crack the passwords using a small set of commonly used passwords
- Attackers use **CrackMapExec** to automate the password spraying process to crack domain or workgroup members' passwords



Mask Attack

- Attackers **recover passwords from hashes** with a specific set of characters based on some information known to the attacker
- Attacker use **hashcat** to perform a mask attack



32

Active Online Attacks: Password Guessing

Frequency of attacks is less

The attacker creates a list of all possible passwords from the information collected through **social engineering** or any other way and manually inputs them on the victim's machine to **crack the passwords**

Failure rate is high



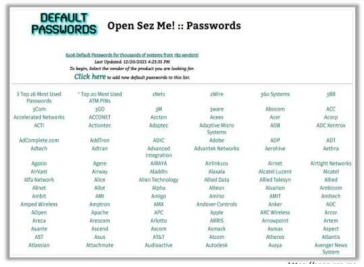


1. Find a **valid** user
2. Create a **list** of possible passwords
3. Rank passwords from **high to low** probability
4. Key in each password, until the **correct password** is discovered

33

Default Passwords

- A default password is a **password supplied by the manufacturer** with new equipment (e.g., switches, hubs, routers) that is password protected
- Attackers use **default passwords** present in the list of words or dictionary that they use to **perform password guessing attack**



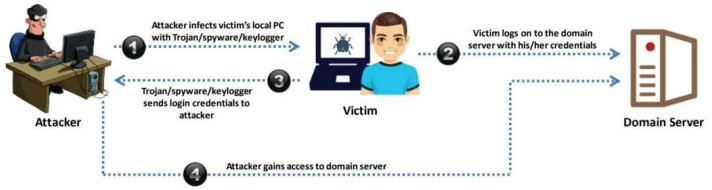
Online Tools to Search Default Passwords

- *https://www.fortypoundhead.com*
- *https://cirt.net*
- *http://www.defaultpassword.us*
- *https://www.routerpasswords.com*
- *https://default-password.info*
- *https://192-168-1-1ip.mobi*

34

Active Online Attacks: Trojans/Spyware/Keyloggers

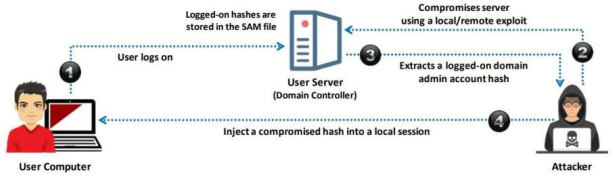
- The attacker installs a Trojan/Spyware/Keylogger on the victim's machine to collect the victim's **usernames and passwords**
- The Trojan/Spyware/Keylogger **runs in the background** and sends back all user credentials to the attacker



35

Active Online Attacks: Hash Injection/Pass-the-Hash (PtH) Attack

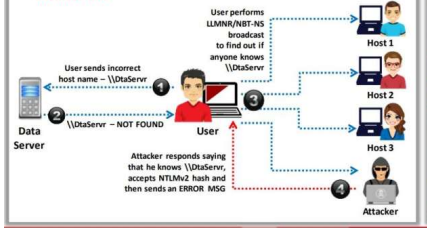
- A hash injection/PtH attack allows an attacker to **inject a compromised hash** into a local session and use the hash to validate network resources
- The attacker finds and extracts a logged-on **domain admin account hash**
- The attacker uses the extracted hash to log on to the **domain controller**



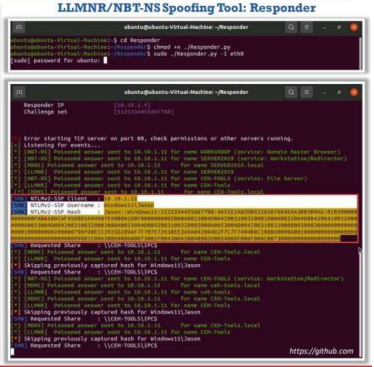
36

Active Online Attacks: LLMNR/NBT-NS Poisoning

- LLMNR and NBT-NS are the two main elements of **Windows operating systems** that are used to perform **name resolution** for hosts present on the same link
- The attacker cracks the **NTLMv2 hash** obtained from the victim's authentication process
- The extracted credentials are used to log on to the **host system in the network**



LLMNR/NBT-NS Spoofing Tool: Responder

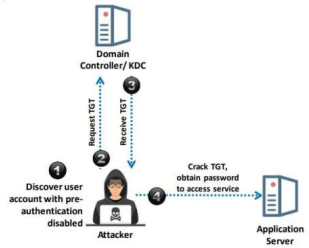


37

Active Online Attacks: Cracking Kerberos Password

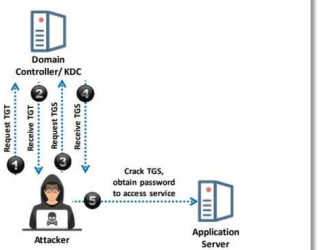
AS-REP Roasting (Cracking TGT)

- Attackers request a TGT from the **KDC** in the form of the an **AS-REQ packet** and crack the ticket to obtain the user's password



Kerberoasting (Cracking TGS)

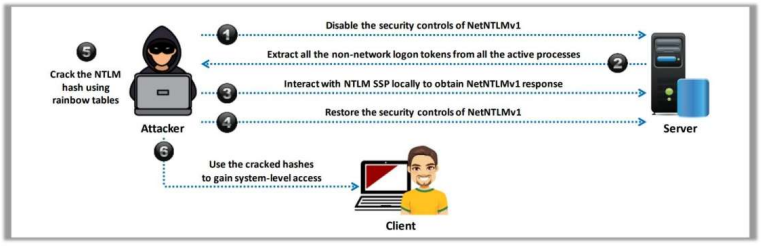
- Attackers request a TGS for the **SPN** of the **target service account** and crack the ticket to obtain the user's password



39

Active Online Attacks: Internal Monologue Attack

- Attackers perform an internal monologue attack using **SSPI** (Security Support Provider Interface) from a user-mode application, where a local procedure call to the **NTLM authentication package** is invoked to calculate the **NetNTLM response** in the context of the logged-on user



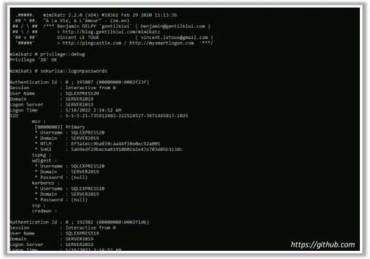
38

Active Online Attacks: Pass the Ticket Attack

- Pass the Ticket is a technique used for **authenticating** a user to a system that is using **Kerberos** without providing the user's password
- To perform this attack, the attacker dumps Kerberos tickets of legitimate accounts using **credential dumping tools**
- The attacker then launches a pass the ticket attack either by **stealing the ST/TGT** from an end-user machine, or by stealing the ST/TGT from a compromised Authorization Server
- The attacker uses the retrieved ticket to gain unauthorized access to the target network services
- Tools such as **Mimikatz**, Rubeus, and Windows Credentials Editor are used by attackers to launch such attacks

Mimikatz

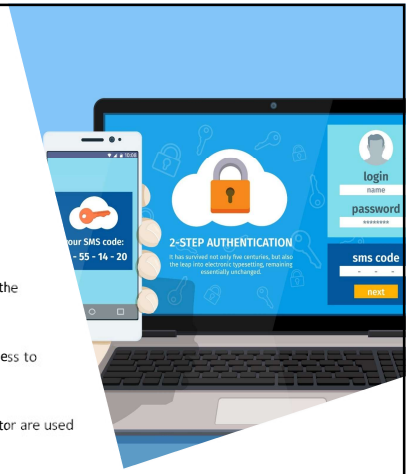
- Mimikatz allows attackers to **pass Kerberos TGT** to other computers and sign in using the victim's ticket
- It also helps in extracting plaintext passwords, hashes, PIN codes, and **Kerberos tickets** from memory



40

Pass the Ticket Active online Attack

- Pass the Ticket is a technique used for **authenticating** a user to a system that is using **Kerberos** without providing the user's password
- To perform this attack, the attacker dumps Kerberos tickets of legitimate accounts using **credential dumping tools**
- The attacker then launches a pass the ticket attack either by **stealing the ST/TGT** from an end-user machine, or by stealing the ST/TGT from a compromised Authorization Server
- The attacker uses the retrieved ticket to gain unauthorized access to the target network services
- Tools such as **Mimikatz**, Rubeus, and Windows Credentials Editor are used by attackers to launch such attacks



41

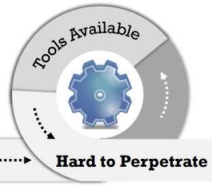
Other Active Online Attacks

Combinator Attack	Attackers combine the **entries of one dictionary** with those of a **second dictionary** to generate a **new wordlist** to crack the password of the target system
Fingerprint Attack	Attackers break down the **passphrase into fingerprints** comprising single and multi-character combinations to crack complex passwords
PRINCE Attack	It is an advanced version of a combinator attack, where attackers use a **single input dictionary** to build chains of combined words instead of taking input from two different dictionaries
Toggle-Case Attack	Attackers attempt all possible combinations of **uppercase and lowercase versions** of a word present in the input dictionary
Markov-Chain Attack	Attackers gather a password database and **split each password** entry into **2- and 3-character-long syllables**; using these character elements, a new alphabet is developed, which is then matched with the existing password database
GPU-based Attack	Attackers exploit the **OpenGL API** on GPUs to **set up a spy** on the victim device that infers user activities and passwords entered on a browser

42

Passive Online Attacks: Wire Sniffing

- Attackers run **packet sniffer tools** on the local area network (LAN) to access and record the raw network traffic
- The captured data may include **sensitive information** such as **passwords** (FTP, rlogin sessions, etc.) and emails
- Sniffed credentials are used to **gain unauthorized access** to the target system



Wire Sniffing ····· **Computationally Complex** ····· **Hard to Perpetrate**



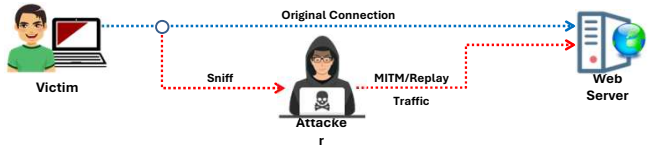
43

Man-in-the-Middle and Replay Attacks

- In an MITM attack, the attacker **acquires access to the communication channels** between the victim and the server to extract the information needed
- In a replay attack, packets and authentication tokens are captured using a **sniffer**. After the relevant information is extracted, the tokens are placed back on the network to gain access

Considerations

- Relatively **hard to perpetrate**
- Must be **trusted** by one or both sides
- Can sometimes be broken by **invalidating traffic**



44

Offline Attacks: Rainbow Table Attack

Rainbow Table — A rainbow table is a precomputed table that contains word lists like **dictionary files**, **brute force lists**, and their **hash values**

Compare the Hashes — The hash **of passwords** is captured and compared with the precomputed hash table. If a match is found, then the password gets cracked

Easy to Recover — It is easy to recover passwords by comparing the captured password hashes to the **precomputed tables**

Precomputed Hashes

1qazwed	4259cc34599c530b28a6a8f225d668590
hh021da	c744b1716cbf8d4dd0ff4ce31a177151
9da8dasf	3cd696a8571a843cda453a229d741843
sodifo8sf	c744b1716cbf8d4dd0ff4ce31a177151

Tool to Create Rainbow Tables: rtgen

- The rtgen program needs **several parameters** to generate a rainbow table. The syntax for the command line is as follows:

Syntax: `rtgen hash_algorithm charset plaintext_len_min plaintext_len_max table_index chain_len chain_num part_index`



http://project-rainbowcrack.com

45

Offline Attacks: Distributed Network Attack

- A Distributed Network Attack (DNA) technique is used for **recovering passwords from hashes or password-protected files** using the unused processing power of machines across the network

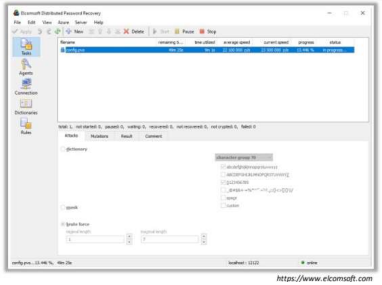
- The DNA Manager is installed in a **central location** where machines running on DNA Client can access it over the network
- The DNA Manager coordinates the attack and **allocates small portions of the key search** to machines that are distributed over the network
- The DNA Client **runs in the background** consuming only unused processor time
- The program combines the processing capabilities of all the clients connected to the network and uses it to **crack the password**

46

Password Recovery Tools

Elcomsoft Distributed Password Recovery

Elcomsoft Distributed Password Recovery breaks **complex passwords**, recovers strong **encryption keys**, and **unlocks documents** in a production environment



https://www.elcomsoft.com

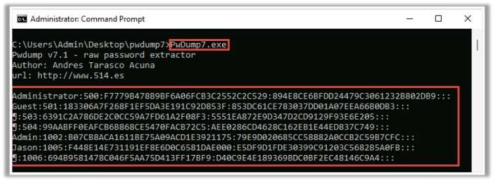
- **Password Recovery Toolkit** — https://accessdata.com
- **Passware Kit Forensic** — https://www.passware.com
- **hashcat** — https://hashcat.net
- **Windows Password Recovery Tool** — https://www.windowspasswordsrecovery.com
- **PCUnlocker** — https://www.top-password.com

47

Tools to Extract the Password Hashes

pwdump7

- pwdump7 **extracts LM** and **NTLM** password hashes of local user accounts from the **Security Account Manager** (SAM) database



https://www.tarasco.org

Tools to Extract the Password Hashes

- Mimikatz (*https://github.com*)
- Powershell Empire (*https://github.com*)
- DSInternals PowerShell (*https://github.com*)
- Ntdsxtract (*https://github.com*)

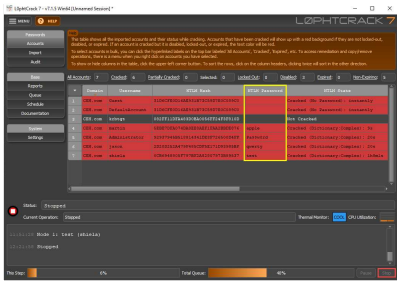
Note: These tools must be run with administrator privileges

48

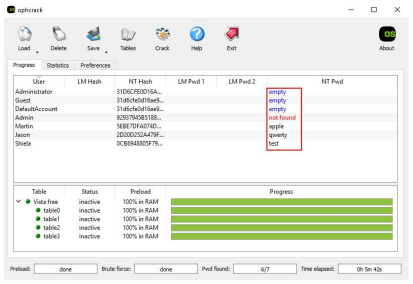
Password-Cracking Tools: L0phtCrack and ophcrack

L0phtCrack A tool designed to **audit passwords** and recover applications

ophcrack A Windows password cracker based on **rainbow tables**. It comes with a Graphical User Interface and runs on multiple platforms



https://www.l0phtcrack.com



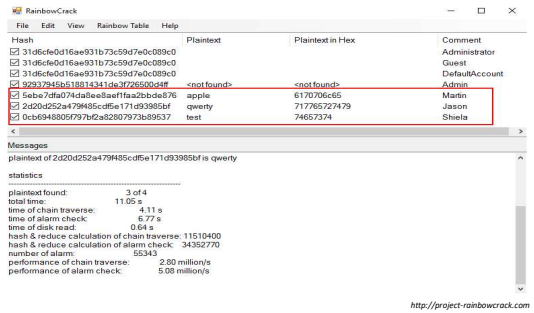
https://ophcrack.sourceforge.io

49

Password-Cracking Tools

RainbowCrack

RainbowCrack cracks hashes with **rainbow tables**. It uses a **time-memory tradeoff** algorithm to crack hashes



http://project-rainbowcrack.com

- **John the Ripper** *https://www.openwall.com*
- **hashcat** *https://hashcat.net*
- **THC-Hydra** *https://github.com*
- **Medusa** *http://foofus.net*

50

Password Cracking Countermeasures

1. Disallow use of the **same password** during a password change
2. Disallow password **sharing**
3. Disallow the use of passwords that can be found in a **dictionary**
4. Do not use **cleartext** protocols and protocols with **weak encryption**
5. Set the **password change policy** to 30 days
6. Do not use any system **default passwords**



51

Password Cracking Countermeasures (Cont'd)

7. Make passwords hard to guess by requiring **8-12 alphanumeric** characters consisting of a combination of uppercase and lowercase letters, numbers, and symbols
8. Ensure that applications **neither store** passwords in memory **nor write** them to disks in clear text
9. Use a **random string** (salt) as a prefix or suffix to the password before encryption
10. Disallow the use of passwords such as **date of birth**, spouse, child's, or pet's name
11. Lockout an account subjected to too many **incorrect password** guesses
12. Use **two-factor or multi-factor authentication**, for example, using CAPTCHA to prevent automated attacks

52